

INFORMATION SECURITY POLICY

Policy Owner: Management / Information Security Responsible Person

Effective Date: 00/002026

Review Date: 00/00/2026

Approved By: Sayed Aslam

1. Purpose

The purpose of this Information Security Policy is to establish the principles, responsibilities, and controls necessary to protect the confidentiality, integrity, and availability of the Company's information assets and information systems.

The Company is committed to implementing and maintaining an Information Security Management System (ISMS) aligned with ISO/IEC 27001 requirements.

2. Scope

This policy applies to:

- All employees
- Contractors
- Temporary staff
- Consultants
- Third-party service providers

It covers:

- Information assets
- Customer information
- Employee information
- IT systems
- Cloud services
- Network infrastructure
- Mobile devices
- Physical records

3. Information Security Objectives

The Company aims to:

- Protect customer and business information.
- Prevent unauthorized access to information systems.
- Ensure business continuity.
- Reduce cybersecurity risks.
- Meet legal, regulatory, and contractual obligations.
- Promote security awareness among employees.
- Continuously improve information security controls.

4. Information Security Principles

All information shall be protected according to:

Confidentiality

Information is accessible only to authorized individuals.

Integrity

Information is accurate, complete, and protected from unauthorized modification.

Availability

Information and systems are available when required for business operations.

5. Roles and Responsibilities

Management

Management shall:

- Approve security policies.
- Allocate resources for security activities.
- Support risk management activities.
- Review security performance regularly.

Employees

Employees shall:

- Follow all security policies and procedures.

- Protect passwords and credentials.
- Report security incidents immediately.
- Participate in security awareness training.

IT Administrator

The IT Administrator shall:

- Manage access controls.
- Monitor security events.
- Maintain system security.
- Apply security updates and patches.
- Conduct backups and recovery testing.

6. Risk Management

The Company shall:

- Maintain a Risk Register.
- Conduct periodic risk assessments.
- Identify threats and vulnerabilities.
- Implement risk treatment measures.
- Review risks annually or when significant changes occur.

Risk treatment options include:

- Mitigate
- Transfer
- Avoid
- Accept

7. Asset Management

The Company shall maintain an Asset Register covering:

- Hardware
- Software
- Cloud resources
- Databases
- Customer data
- Business information

All assets shall have an assigned owner.

8. Access Control Policy

Access to systems and information shall be granted according to business requirements.

Requirements

- Unique user accounts.
- Strong password policy.
- Multi-Factor Authentication (MFA) where feasible.
- Least privilege principle.
- Regular access reviews.
- Immediate removal of access upon employee departure.

Shared accounts are prohibited unless formally approved.

9. Password Policy

Passwords must:

- Be at least 12 characters long.
- Contain a combination of letters, numbers, and symbols.
- Not be reused across systems.
- Not be shared.

Password managers are recommended.

10. Endpoint Security

All company devices must:

- Run approved antivirus/EDR software.
- Receive security updates regularly.
- Have device encryption enabled where possible.
- Be protected by screen lock mechanisms.

Unauthorized software installation is prohibited.

11. Email Security

To mitigate phishing risks:

- Employees must verify suspicious emails.
- Attachments and links from unknown sources shall not be opened.

- Email filtering and anti-spam controls shall be enabled.
- Security awareness training shall be conducted regularly.

12. Network Security

The Company shall maintain secure network infrastructure through:

- Firewalls
- VPNs for remote access
- Secure Wi-Fi configurations
- Network segmentation where appropriate
- Monitoring of network traffic

Default vendor passwords shall be changed immediately.

13. Malware Protection

The Company shall:

- Deploy antivirus/EDR solutions.
- Maintain updated malware signatures.
- Monitor security alerts.
- Investigate suspicious activity promptly.

14. Backup and Recovery

The Company shall:

- Perform regular backups of critical data.
- Store backups securely.
- Test restoration procedures periodically.
- Maintain recovery procedures for critical systems.

Backup failures must be investigated immediately.

15. Vulnerability and Patch Management

The Company shall:

- Monitor for security vulnerabilities.
- Apply critical patches promptly.
- Maintain supported software versions.

- Review systems regularly for security weaknesses.

16. Physical Security

The Company shall:

- Restrict physical access to sensitive equipment.
- Secure offices outside working hours.
- Protect devices against theft.
- Maintain visitor controls where appropriate.

17. Supplier Security

Third-party suppliers shall be assessed before being granted access to Company systems or data.

Security requirements shall be included in contracts where appropriate.

18. Incident Management

Employees must immediately report:

- Malware infections
- Phishing attempts
- Data breaches
- Lost devices
- Unauthorized access attempts

All incidents shall be documented and investigated.

Root cause analysis shall be performed for significant incidents.

19. Security Awareness and Training

All employees shall receive:

- Security awareness training
- Phishing awareness training
- Policy awareness training

Training records shall be maintained.

20. Business Continuity

The Company shall maintain plans to:

- Restore critical systems.
- Recover data.
- Continue essential business operations during disruptions.

21. Monitoring and Logging

Security logs shall be retained and reviewed where practical.

Monitoring activities may include:

- Login monitoring
- Endpoint monitoring
- Firewall logs
- Security alerts
- Backup monitoring

22. Compliance

All employees must comply with:

- Company policies
- Applicable laws and regulations
- Contractual obligations
- Data protection requirements

Violations may result in disciplinary action.

23. Continuous Improvement

The Company commits to continual improvement of its information security program through:

- Risk reviews
- Security assessments
- Incident reviews
- Internal audits
- Management reviews

24. Policy Review

This policy shall be reviewed:

- Annually, or
- Following significant organizational, technological, or regulatory changes.

Approved By:

Name: Sayed Aslam

Title: Cybersecurity Professional Enthusiast

Date: 00/00/2026